NIST Special Publication 800-46
Revision 2

Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security

Murugiah Souppaya
Karen Scarfone

This publication is available free of charge from:
http://dx.doi.org/10.6028/NIST.SP.800-46r2

C O M P U T E R S E C U R I T Y

National Institute of
Standards and Technology
U.S. Department of Commerce

Authority

This publication has been developed by NIST in accordance with its statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3541 *et seq.*, Public Law (P.L.) 113-283. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems, but such standards and guidelines shall not apply to national security systems without the express approval of appropriate federal officials exercising policy authority over such systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130.

Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, Director of the OMB, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

National Institute of Standards and Technology Special Publication 800-46 Revision 2
Natl. Inst. Stand. Technol. Spec. Publ. 800-46 Rev. 2, 53 pages (July 2016)
CODEN: NSPUE2

This publication is available free of charge from:
http://dx.doi.org/10.6028/NIST.SP.800-46r2

Certain commercial entities, equipment, or materials may be identified in this document in order to describe an experimental procedure or concept adequately. Such identification is not intended to imply recommendation or endorsement by NIST, nor is it intended to imply that the entities, materials, or equipment are necessarily the best available for the purpose.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by Federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, Federal agencies may wish to closely follow the development of these new publications by NIST.

Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at http://csrc.nist.gov/publications.

Comments on this publication may be submitted to:

National Institute of Standards and Technology
Attn: Computer Security Division, Information Technology Laboratory
100 Bureau Drive (Mail Stop 8930) Gaithersburg, MD 20899-8930

All comments are subject to release under the Freedom of Information Act (FOIA).

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

Executive Summary

For many organizations, their employees, contractors, business partners, vendors, and/or other users utilize enterprise telework technologies to perform work from external locations. Most of these people use remote access technologies to interface with an organization's non-public computing resources. The nature of telework and remote access technologies—permitting access to protected resources from external networks and often externally controlled hosts as well—generally places them at higher risk than similar technologies only accessed from inside the organization, as well as increasing the risk to the internal resources made available to users through remote access.

All the components of telework and remote access solutions, including client devices, remote access servers, and internal resources accessed through remote access, should be secured against expected threats, as identified through threat models. Major security concerns include the lack of physical security controls, the use of unsecured networks, the connection of infected devices to internal networks, and the availability of internal resources to external hosts.

There are additional security concerns for organizations that permit the use of client devices outside the organization's control, referred to in this publication as third-party-controlled technologies. These include contractor, business partner, and vendor-controlled devices, as well as personally owned (bring your own device, BYOD[1]) employee, contractor, business partner, and vendor laptops, smartphones, and tablets. Even though the organization may have agreements with employees and third parties that require their client devices to be properly secured, those agreements generally cannot be automatically enforced, so unsecured, malware-infected, and/or otherwise compromised devices may end up connected to sensitive organizational resources.

This publication provides information on security considerations for several types of remote access solutions, and it makes recommendations for securing a variety of telework, remote access, and BYOD technologies. It also gives advice on creating related security policies. To improve the security of organizations' telework and remote access technologies, as well as better mitigate the risks posed by BYOD and third-party-controlled technologies to enterprise networks and systems, organizations should implement the following recommendations:

Plan telework-related security policies and controls based on the assumption that external environments contain hostile threats.

An organization should assume that external facilities, networks, and devices contain hostile threats that will attempt to gain access to the organization's data and resources. Organizations should assume that telework client devices, which are used in a variety of external locations and are particularly prone to loss or theft, will be acquired by malicious parties who will either attempt to recover sensitive data from them or leverage the devices to gain access to the enterprise network. Options for mitigating threats of loss or theft include encrypting the device's storage, encrypting all sensitive data stored on client devices, or not storing sensitive data on client devices. For mitigating device reuse threats, the primary option is using strong authentication—preferably multi-factor—for enterprise access.

Organizations should also assume that communications on external networks, which are outside the organization's control, are susceptible to eavesdropping, interception, and modification. This type of

[1] Strictly speaking, BYOD devices could be used only within the enterprise, and not for telework or remote access. However, the vast majority of BYOD devices are used externally, so for the purposes of this publication, all BYOD devices are considered telework devices. Also, the security concerns associated with enterprise-only BYOD devices are nearly identical to those for telework BYOD devices.

threat can be mitigated, but not eliminated, by using encryption technologies to protect the confidentiality and integrity of communications, as well as authenticating each of the endpoints to each other to verify their identities.

Another important assumption is that telework client devices will become infected with malware; possible controls for this include using antimalware technologies, using network access control solutions that verify the client's security posture before granting access, and using a separate network at the organization's facilities for telework client devices brought in for internal use (see the final recommendation in the Executive Summary for additional information).

Develop a telework security policy that defines telework, remote access, and BYOD requirements.

A telework security policy should define which forms of remote access the organization permits, which types of telework devices are permitted to use each form of remote access, and the type of access each type of teleworker is granted. It should also cover how the organization's remote access servers are administered and how policies in those servers are updated.

As part of creating a telework security policy, an organization should make its own risk-based decisions about what levels of remote access should be permitted from which types of telework client devices. For example, an organization may choose to have tiered levels of remote access, such as allowing organization-owned personal computers (PCs) to access many resources, BYOD PCs and third-party-controlled client devices to access a limited set of resources, and BYOD smartphones and tablets to access only one or two lower-risk resources, such as webmail. Having tiered levels of remote access allows an organization to limit the risk it incurs by permitting the most-controlled devices to have the most access and the least-controlled devices to have minimal access.

There are many factors that organizations should consider when setting policy regarding levels of remote access to grant; examples include the sensitivity of the telework, the level of confidence in the telework client device's security posture, the cost associated with telework devices, the locations from which telework is performed, and compliance with mandates and other policies. For telework situations that an organization determines are particularly high-risk, an organization may choose to specify additional security requirements. For example, high-risk telework might be permitted only from organization-issued and secured telework client devices that employ multi-factor authentication and storage encryption. Organizations may also choose to reduce risk by prohibiting telework and remote access involving particular types of information, such as sensitive personally identifiable information (PII).[2]

Ensure that remote access servers are secured effectively and are configured to enforce telework security policies.

The security of remote access servers is particularly important because they provide a way for external hosts to gain access to internal resources, as well as a secured, isolated telework environment for organization-issued, third-party-controlled, and BYOD client devices. In addition to permitting unauthorized access to enterprise resources and telework client devices, a compromised server could be used to eavesdrop on communications and manipulate them, as well as to provide a "jumping off" point for attacking other hosts within the organization. It is particularly important for organizations to ensure that remote access servers are kept fully patched and that they can only be managed from trusted hosts by authorized administrators. Organizations should also carefully consider the network placement of remote access servers; in most cases, a server should be placed at an organization's network perimeter so that it

[2] More information on protecting PII is available from NIST Special Publication 800-122, *Guide to Protecting the Confidentiality of Personally Identifiable Information (PII)* (http://dx.doi.org/10.6028/NIST.SP.800-122).

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

acts as a single point of entry to the network and enforces the telework security policy before any remote access traffic or other traffic from telework client devices (such as BYOD devices using an organization's wireless BYOD network) is permitted into the organization's internal networks.

Secure organization-controlled telework client devices against common threats and maintain their security regularly.

There are many threats to telework client devices, including malware and device loss or theft. Generally, telework client devices should include all the local security controls used in the organization's secure configuration baseline for its non-telework client devices.[3] Examples are applying operating system and application updates promptly, disabling unneeded services, and using antimalware software and a personal firewall. However, because telework devices are generally at greater risk in external environments than in enterprise environments, additional security controls are recommended, such as encrypting sensitive data stored on the devices, and existing security controls may need to be adjusted. For example, if a personal firewall on a telework client device has a single policy for all environments, then it is likely to be too restrictive in some situations and not restrictive enough in others. Whenever possible, organizations should use personal firewalls capable of supporting multiple policies for their telework client devices and configure the firewalls properly for the enterprise environment and an external environment, at a minimum.

Organizations should ensure that all types of telework client devices are secured, including PCs, smartphones, and tablets. For PCs, this includes physical security. For devices other than PCs, security capabilities and the appropriate security actions vary widely by device type and specific products, so organizations should provide guidance to device administrators and users who are responsible for securing telework mobile devices on how they should secure them.

If external device use (e.g., BYOD, third-party controlled) is permitted within the organization's facilities, strongly consider establishing a separate, external, dedicated network for this use.

Allowing personally owned and third-party-controlled client devices to be directly connected to an organization's enterprise networks adds considerable risk if the devices are placed on the organization's internal networks, because these devices are often not secured to the same degree as the organization's own devices. However, this risk can largely be mitigated by setting up a separate wired or wireless network within the enterprise dedicated to these devices. This network should be external (e.g., off the organization's demilitarized zone [DMZ]) and not grant any more access to enterprise resources than users already have through remote access. This network should be secured and monitored in a manner consistent with how remote access segments are secured and monitored.

[3] The National Checklist Repository (http://checklists.nist.gov/) is a source of security configuration baseline information.

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

For the same reasons discussed in Section 2.2.3, the direct application access architecture is generally only acceptable if the servers being accessed by the teleworkers are located on the organization's network perimeter or in a public-facing cloud, and not internal networks. Servers that are directly accessible from the Internet should already be well-secured to reduce the likelihood of compromise. Many organizations choose to provide direct application access to only a few lower-risk applications that are widely used, such as email, and use tunnel or portal methods to provide access to other applications, particularly those that would be at too much risk if they were directly accessible from the Internet.

2.3 BYOD and Third-Party-Controlled Client Device Considerations

For many years, it has been a common practice for organizations to permit remote access and telework to be performed from employees', contractors', business partners', and vendors' personally owned computing devices. A more recent trend, BYOD, expands on this telework concept to allow these devices to be directly connected to an organization's enterprise networks. This adds considerable risk to an organization if the devices are placed on the organization's internal networks, because BYOD devices, which are managed by the users themselves, are typically not secured to the same degree as the organization's own devices. However, this risk can largely be mitigated by setting up a separate wired or wireless network within the enterprise dedicated to BYOD devices.[15] This BYOD network should be external (e.g., off the organization's DMZ) and not grant any more access to enterprise resources than users already have through remote access. Organizations considering permitting BYOD devices within the enterprise should strongly consider establishing a separate, external, dedicated network for BYOD use within enterprise facilities. This network should be secured and monitored in a manner consistent with how remote access segments are secured and monitored.

The risks of BYOD and third-party-controlled client devices specifically are quite similar to those of general telework and remote access. However, there are a few important distinctions:

- Malicious traffic generated by a BYOD or third-party-controlled client device on an enterprise network may appear to external parties to be generated by the organization itself. This could affect the organization's reputation.
- BYOD and/or third-party-controlled devices may attack each other over the dedicated network.

2.4 Summary of Key Recommendations

The following list presents some of the key recommendations from this section of the document.

- To support confidentiality, integrity, and availability, all of the components of telework and remote access solutions, including client devices, remote access servers, and internal servers accessed through remote access, should be secured against a variety of threats. (Section 2.1)
- Before designing and deploying telework and remote access solutions, organizations should develop system threat models for the remote access servers and the resources that are accessed through remote access. (Section 2.1)
- When planning telework security policies and controls, organizations should assume that client devices will be acquired by malicious parties who will either attempt to recover sensitive data from the devices or leverage the devices to gain access to the enterprise network. (Section 2.1)

[15] A similar network can be set up for third-party-controlled devices if desired, or the same network used for both BYOD and third-party-controlled devices. However, often this is not necessary because there are already contractual agreements and technical checks in place to ensure that these devices are secured in accordance with the organization's policies.

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

- Organizations should plan their remote access security on the assumption that the networks between the telework client device and the organization cannot be trusted. (Section 2.1)
- Organizations should assume that client devices will become infected with malware and plan their security controls accordingly. (Section 2.1)
- Organizations should carefully consider the balance between the benefits of providing remote access to additional resources and the potential impact of a compromise of those resources. Organizations should ensure that any internal resources they choose to make available through remote access are hardened appropriately against external threats and that access to the resources is limited to the minimum necessary through firewalling and other access control mechanisms. (Section 2.1)
- When planning a remote access solution, organizations should carefully consider the security implications of the remote access methods in each of the four categories described in Section 2.2, in addition to how well each method may meet operational requirements. (Section 2.2)
- Organizations considering permitting BYOD devices within the enterprise should strongly consider establishing a separate, external, dedicated network for BYOD use within enterprise facilities. Such a network may also be used for third-party-controlled client devices if desired. (Section 2.3)

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

- Determine if the device manufacturer provides updates and patches; if so, ensure that they are applied promptly to protect the device from attacks against known vulnerabilities.
- Strongly encrypt stored data on both built-in storage and removable media.
- Require a password/passcode and/or other authentication before accessing the organization's resources.
- Restrict which applications may be installed through whitelisting or blacklisting.[32]

Given the similarity between the functions of mobile devices, particularly as they become more advanced, and PCs, organizations should strongly consider treating them similar to, or the same as, PCs. This means that organizational policies for PCs may simply be extended to mobile devices; if the two policies are kept separate, the policy documents should heavily cross-reference each other.

Organizations should consider taking advantage of mobile device management (MDM) solutions, mobile application management solutions (MAM), and other technologies for controlling the use of mobile devices. MDM solutions are capable of enforcing a variety of security policies on behalf of the organization, even to some extent on mobile devices that are not controlled by the organization. For example, MDM software is frequently used to require the use of a PIN to unlock a mobile device, to enable encryption technologies to protect sensitive data stored on a mobile device, and to determine if a mobile device has been jailbroken or rooted. MDM software can also be used to perform a remote wipe when a mobile device has been lost or stolen to prevent unauthorized access to any sensitive data it contains. An organization can set different MDM policies for each category of mobile devices, such as organization-issued, third-party-controlled, and BYOD, to take into account the differing levels of access each device may provide to the MDM solution. MAM software provides an environment that isolates the enterprise applications and data from the rest of the device. Strong authentication can be required to access the enterprise environment, which is also encrypted to protect the organization's sensitive data and applications, and to minimize data leakage from those applications to other applications and services running on the device. In the event the device is lost or the employee leaves the organization, the protected environment can be remotely wiped to remove the enterprise data.

In addition to or instead of MDM/MAM solutions, organizations may rely on NAC solutions, as discussed in Sections 2 and 3 of this document. NAC solutions can identify jailbroken or rooted mobile devices and other major security policy violations on mobile devices attempting to connect to the organization's networks.

4.3 Protecting Data on Telework Client Devices

Telework often involves creating and editing work-related information such as email, word processing documents, and spreadsheets. Because that data is important, it should be treated like other important assets of the organization. Two things an organization can do to protect data on telework devices are to secure it on the telework device and to periodically back it up to a location controlled by the organization. More information on this is provided in Sections 4.3.1 through 4.3.3. Organizations can also choose not to allow the organization's information to be stored on telework devices, but to instead store it centrally at the organization.

Sensitive information, such as certain types of personally identifiable information (PII) (e.g., personnel records, medical records, financial records), that is stored on or sent to or from telework devices should be protected so that malicious parties cannot access or alter it. For example, teleworkers often forget that

[32] For more information on application whitelisting, see NIST SP 800-167, *Guide to Application Whitelisting* (http://dx.doi.org/10.6028/NIST.SP.800-167).

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

storing sensitive information on a CD that is carried with their device, or printing the information on a public printer, can also expose the information in ways that are not significant within a typical enterprise environment. An unauthorized release of sensitive information could damage the public's trust in an organization, jeopardize the organization's mission, or harm individuals if their personal information has been released.

4.3.1 Encrypting Data at Rest

All telework devices, regardless of their size or location, can be stolen. Some thieves may want to read the contents of the data on the device, and quite possibly use that data for criminal purposes. To prevent this, an organization should have a policy of encrypting all sensitive data when it is at rest on the device and on removable media used by the device. The creation and use of cryptographic keys for encrypting remote data at rest should follow the same policies that an organization has for other keys that protect data at rest.[33]

There are many methods for protecting data at rest, and they mostly depend on the type of device or removable media that is being protected. Most operating systems have their own data encryption mechanisms, and there are also numerous third-party applications that provide similar capabilities.[34] Generally, when technologies such as full disk encryption are being used to protect data at rest on PCs, teleworkers should shut down their telework devices instead of placing them into sleep mode when the devices will not be used for an extended time or when the teleworker will not be with the device. This helps ensure that the data at rest and the decryption key are protected by the storage encryption technology.

4.3.2 Using Virtual Machines

If an organization has direct control over a telework device, the organization can enforce its policies for remote access, updating, etc. For other telework devices, such as BYOD PCs, the organization has a limited ability to enforce security policies. A method for controlling the environment in which a teleworker operates is to run a virtual machine (VM) on the telework PC. This is normally done by running a VM *hypervisor* program within the telework PC's operating system, but some newer telework PCs allow the installation of a hypervisor that runs in place of the PC's operating system. This is known as a *bare-metal hypervisor*. Bare-metal hypervisors are generally considered more secure than other hypervisors because there is one less major piece of software that can be attacked.[35]

A user runs a VM *image* in the virtual machine environment; this image acts just like a full computer with an operating system and application software. (Using virtual machines as telework devices is an extension of the concept of thin clients.) To use VM images to enforce telework policy, the organization distributes a VM image that is configured to be fully compliant with all relevant security policies. The teleworker runs the VM image on the telework computer. When the image needs to be updated, the organization distributes a new image to its teleworkers. Using a VM to support telework security works well as long as the telework computer itself does not have any malware that will attack the VM. For hypervisors that run within the host OS (i.e., not bare-metal hypervisors), any compromise within the host OS could affect the security of the VM and the VM image.

---

[33] For more information on cryptographic key usage, see NIST SP 800-57 (Parts 1-3), *Recommendation for Key Management* (http://csrc.nist.gov/publications/PubsSPs.html#800-57pt1).

[34] See NIST SP 800-111, *Guide to Storage Encryption Technologies for End User Devices*, for more information on encrypting storage on client devices and removable media (http://dx.doi.org/10.6028/NIST.SP.800-111).

[35] More information on hypervisors is available from NIST SP 800-125, *Guide to Security for Full Virtualization Technologies* (http://dx.doi.org/10.6028/NIST.SP.800-125).

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2

VM disks act just like the disks on a regular computer, so organizations should have policies for telework data that is stored in a VM image. VM images can be encrypted on the telework computer when they are not in use and only decrypted after the user provides proper authentication just before booting an image. If VM images are encrypted, an unauthorized person that gets access to the telework device will not be able to read the data stored in the VM image. Similarly, a VM image can have multiple disks within it, and some of those can be encrypted; if the teleworker stores their data on an encrypted disk within the VM, it will be just as if the data were stored on an encrypted disk directly on the telework computer.

Organizations should consider encrypting all VM images used for telework to reduce the risk of compromise. This can be accomplished through the use of full disk encryption, file encryption, or other means.[36] For high-risk situations, particularly involving access to highly sensitive information, organizations should encrypt each individual VM image used for telework and may also want to provide a second layer of protection through full disk encryption.

4.3.3 Backing Up Data on Telework Devices

Most organizations have policies for backing up data on a regular basis. Such a backup policy should cover data on telework PCs and mobile devices. However, such a policy may need different provisions for backups performed at the organization's facilities versus external locations. If the data to be backed up contains sensitive information or needs its confidentiality protected for other reasons, there are additional security considerations if that backup is performed at an external location.

If data is being backed up remotely—from the telework device to a system at the organization—then the communications carrying that data should be encrypted and have their integrity verified. This is discussed in more detail in Section 3.3.3. If data is being backed up locally—to removable media such as CDs or flash drives, for example—the backup should be protected at least as well as the original data is. For example, if the original data is encrypted, then the data in the backup should be encrypted as well. If the original data is encrypted in a portable form, such as through virtual disk encryption or an encrypted VM image, then it may be sufficient to copy that encrypted entity onto the backup media. However, for non-portable forms of storage encryption, such as full disk encryption, the data would need to be decrypted on the telework device and then encrypted for storage on the backup media.

4.4 Summary of Key Recommendations

The following list presents some of the key recommendations from this section of the document.

- Telework client devices should be secured properly and have their security maintained regularly. Generally, telework client devices should have the same local security controls as other client devices in the enterprise. However, because of the threats that client devices face in external environments, additional security controls are recommended, and some security controls may need to be adjusted to work effectively in telework environments. If the use of additional security controls is not feasible or enforceable, other approaches may be better, such as using VDI or VMI technologies or bootable removable media to establish a secure environment, or adopting MDM solutions for enhancing and enforcing mobile device security. (Section 4 introduction)
- For telework PCs, personal firewalls capable of supporting multiple policies should be used whenever possible and configured properly for the enterprise environment and an external environment, at a minimum. (Section 4.1)

[36] NIST SP 800-111, *Guide to Storage Encryption Technologies for End User Devices*, explains these options (http://dx.doi.org/10.6028/NIST.SP.800-111).

This publication is available free of charge from: http://dx.doi.org/10.6028/NIST.SP.800-46r2